Commitment-Bound Selective Disclosure for Patient-Held Health Records on Solana and IPFS

M. Jabez Joshwin Paul and E. Bijolin Edwin

***Abstract*—Patients are often asked to prove a simple fact about their health record, such as having received at least a required number of vaccine doses, and end up disclosing the whole record. Zero-knowledge proofs can answer such a question without revealing the data, but a proof is only meaningful if it is tied to a stored record and to a verification session. We start from a prototype that stored an encrypted record on IPFS and its content identifier on Solana, in which a server computed the threshold proof from the private value and the proof referred to no record. We redesign the proof path: a salted Poseidon commitment to the private value is stored in the record's on-chain account and is also an output of the circuit; a verifier-chosen challenge is a public input; input ranges are enforced inside the circuit; and proofs are generated in the owner's browser. We implement the design with Circom, snarkjs and the Anchor framework and measure it on a laptop. The bound circuit has 339 constraints against 37 for the baseline. A Groth16 proof takes a median of 89.4 ms to generate in a browser and 13.4 ms to verify. Each record occupies a 212-byte account with a refundable deposit of 0.0023664 SOL, and its creation consumes at most 13,402 compute units. We analyse the security of the design and state its limitations, chief among them that the committed value is self-asserted.**

***Index Terms*—Zero-knowledge proofs, selective disclosure, personal health records, blockchain, Solana, IPFS.**

I. Introduction

A personal health record is a health record that the individual, rather than a care provider, controls and shares [1], [2]. Putting the individual in control raises a practical question each time the record is used: how much of it must be shown? Many everyday checks need only a yes-or-no fact. A school, an employer or a border officer may need to know that a person has received at least a required number of vaccine doses, and has no need for the dates, the products, or the rest of the record. Handing over the whole document to answer such a question discloses far more than the question requires, which is at odds with the data-minimisation principle found in data-protection law [3].

Blockchains have been studied extensively as a substrate for health records because they give patients and institutions a shared, tamper-evident log without a single operator [4], [5]. Most proposals keep the record itself off-chain, encrypted, and use the chain to manage pointers and permissions [6]–[11]. In these designs the unit of sharing is still the record or a part of it: a party that is granted access decrypts and reads the data. Zero-knowledge proofs [12] offer a different unit of sharing, namely a statement about the data, and succinct non-interactive constructions [13], [14] make such statements cheap to check.

A zero-knowledge proof about a health value is only useful to a verifier if it is anchored to something. A proof that "I know a number that is at least two" convinces nobody of anything. Three questions have to be answered by the surrounding system: which stored record does the proof speak about, who learned the secret while the proof was being made, and can a proof made for one verifier be shown to another. This paper starts from a small working prototype in which none of the three had a satisfactory answer. In that baseline, the encrypted record was pinned to the InterPlanetary File System (IPFS) and its content identifier was stored on Solana, but the threshold proof was computed by a server that received the private value in clear, and the proof contained nothing that connected it to the stored record or to a particular verification session.

We redesign the proof path to close these gaps and measure what the redesign costs. The contributions are as follows.

1) *A commitment-bound disclosure design.* A salted Poseidon commitment to the private value is stored in the record's on-chain account when the record is created, and the circuit outputs the same commitment. A verifier accepts a proof only if its commitment equals the one read from the chain. A verifier-chosen challenge is a public input of the circuit, which ties each proof to one verification session. Proofs are generated on the owner's device, so no other party sees the private value.
2) *A working implementation* on Solana (using the Anchor framework), IPFS, Circom and snarkjs, with automated tests for the circuit, the on-chain program and the client logic.
3) *A reproducible measurement* of the cost of the design on commodity hardware: circuit size, proving and verification time in Node.js and in a web browser, client-side encryption time, and on-chain storage and execution cost. Every figure reported here is produced by a script included with the implementation.
4) *An explicit account of what the design does not provide*, including the absence of an issuer attestation, the single-party setup, and the information a verifier can extract by repeated queries.

We do not claim a new cryptographic primitive. The building blocks are standard; the contribution is their composition for this use case, an implementation, and measurements that

M. Jabez Joshwin Paul is with the Division of Computer Science and Engineering, Karunya Institute of Technology and Sciences, Coimbatore, Tamil Nadu, India (e-mail: jabezjoshwin@gmail.com).

E. Bijolin Edwin is with the Department of Computer Science and Engineering, Karunya Institute of Technology and Sciences, Coimbatore, Tamil Nadu, India.

others can repeat.

The rest of the paper is organised as follows. Section II introduces the building blocks and Section III reviews related work. Section IV presents the threat model and the design, Section V the implementation, and Section VI the evaluation. Section VII analyses security and limitations, and Section VIII concludes.

II. Background

A. Zero-knowledge succinct arguments

A zero-knowledge proof lets a prover convince a verifier that a statement is true without revealing why it is true [12]. A zk-SNARK is a non-interactive argument of this kind whose proofs are short and fast to verify. Pinocchio [13] made such arguments practical for general computations, and Zerocash [15] and Hawk [16] brought them to blockchains; a survey of their use in that setting is given by Sun et al. [17].

We use the pairing-based argument of Groth [14]. The computation to be proved is written as a rank-1 constraint system (R1CS) over a prime field. A Groth16 proof consists of three group elements, and verification checks one pairing-product equation using three pairings [14]. The scheme needs a structured reference string that is specific to the circuit and is produced by a setup procedure; whoever knows the randomness of that procedure can forge proofs, which is why multi-party procedures for sampling the parameters have been developed [18]. Our implementation works over a Barreto–Naehrig pairing-friendly curve [19], the curve that snarkjs calls `bn128`. Alternatives that avoid a trusted setup exist, for example Bulletproofs [20], whose range proofs fit this kind of statement at the price of larger proofs and slower verification than Groth16.

Circuits are written in Circom [21], a language that compiles a description of signals and constraints into an R1CS and a WebAssembly witness generator. Proving and verification use snarkjs [22]. A known hazard of this style of programming is the *under-constrained* circuit, in which the constraints admit witnesses that the programmer did not intend, so that a malicious prover can obtain an accepting proof for a false statement [23]. This hazard shaped the range checks in Section IV-F.

B. Poseidon

Conventional hash functions such as SHA-256 are expensive to express as arithmetic constraints. Poseidon [24] is a hash function designed to operate natively on prime-field elements so that it needs far fewer constraints inside a proof system. We use it as a commitment: the commitment to a value v with random salt s is $C = H(v, s)$, where H is Poseidon with two inputs.

C. Solana accounts and program-derived addresses

Solana stores all state in accounts. Every account has the same five fields, among them a data buffer and an owner, and only the program that owns an account may modify its data [25]. An account must hold a refundable minimum balance proportional to its size to remain on chain [25]. A program-derived address (PDA) is an account address computed deterministically from a program identifier and a list of seeds; it does not lie on the Ed25519 curve, so no private key exists for it [26]. A transaction is limited to 1,232 bytes [27]; it pays a base fee of 5,000 lamports per signature, and each instruction has a default budget of 200,000 compute units [28]. One SOL is 10^9 lamports. Anchor is a framework that generates account validation and serialisation code for Solana programs from declarative annotations [29].

D. IPFS

IPFS is a peer-to-peer storage network in which data is addressed by a content identifier (CID) derived from a cryptographic hash of the data itself [30], [31]. Because the address is a function of the content, anyone who retrieves the data can check that it has not been altered. Content remains retrievable only while some node keeps it; *pinning* services keep content on behalf of users [32]. IPFS provides no confidentiality: anyone who knows a CID can request the content, so private data must be encrypted before it is added.

E. Password-based authenticated encryption

AES in Galois/Counter Mode (GCM) is an authenticated encryption mode; NIST recommends a 96-bit initialisation vector for it [33]. PBKDF2 derives a symmetric key from a passphrase by iterating a pseudorandom function over the passphrase and a salt [34], [35]. Both are available in browsers through the Web Cryptography API [36]. The iteration count determines the cost of each passphrase guess; NIST SP 800-132 asks for a count as large as is feasible [35], and current OWASP guidance recommends 600,000 iterations for PBKDF2 with HMAC-SHA-256 [37].

III. Related Work

a) Blockchain-based health record management: Zyskind et al. [7] proposed keeping personal data off-chain and using a blockchain as an access-control manager. MedRec [6] applied the idea to medical records, using smart contracts to manage permissions over records that remain with providers. Yue et al. [38] described a gateway application that lets patients own and control their data. Ancile [8] combines smart contracts with further cryptographic techniques for access control and interoperability, and MeDShare [9] records data-sharing actions among cloud custodians on a blockchain to provide provenance and auditing. FHIRChain [39] builds a blockchain-based architecture around the HL7 FHIR standard for sharing clinical data. Shahnaz et al. [10] and Tanwar et al. [40] present frameworks for electronic health records with access rules enforced on a blockchain. Sun et al. [11] store encrypted medical records in IPFS and control access with ciphertext-policy attribute-based encryption. Surveys of the area identify privacy, scalability and regulatory compliance as open challenges [4], [5], [41].

These systems answer the question of *who may read a record*. Once access is granted, the reader obtains the data.

Our work addresses a complementary question, namely how an owner can let a verifier check a predicate over a record without granting read access at all.

b) Zero-knowledge proofs and credentials in health applications: Sharma et al. [42] combine zero-knowledge proofs with proxy re-encryption in a blockchain framework for managing access to health records and funds. Selective disclosure has a long history in anonymous credential systems [43], and the W3C Verifiable Credentials data model [44] standardises a format for issuer-signed credentials in which a holder can choose what to disclose, including through zero-knowledge mechanisms. Those systems rest on an issuer who signs the attributes. Our prototype has no issuer; the on-chain commitment fixes a value at a point in time but does not attest that the value is true. We return to this limitation in Section VII-B.

c) Positioning: We are not aware of a published measurement of a commitment-bound threshold proof for health records on Solana with client-side proving, but we have not carried out a systematic review and make no claim of being first. We do not compare our measurements numerically with the systems above: they run on different ledgers, solve different problems and report different metrics, so a side-by-side table of numbers would not be meaningful.

IV. System Design

A. Roles and threat model

The system has three roles. The *owner* holds a health record and a wallet key. A *verifier* wants to know whether a numeric field of the record, here the vaccination count, is at least some threshold. The *infrastructure* consists of the Solana ledger, the IPFS network with a pinning service, and a web server that delivers the application code.

We consider the following adversaries.

- *Chain and storage observers.* Everything written to Solana and to IPFS is public and permanent for practical purposes. Observers try to learn the contents of records from it.
- *A curious verifier.* The verifier follows the protocol but tries to learn more than the truth of the predicate.
- *A dishonest prover.* A party tries to make a verifier accept a statement that is false for the record at a given address, or to reuse a proof it obtained from someone else.
- *A curious service operator.* The operators of the pinning service and of any auxiliary server try to learn private values from what passes through them.

We assume that the owner's device and browser are not compromised, that the application code and the verification key reach each party unmodified, that the setup of the proof system was honest, and that the cryptographic primitives are secure. The owner is *not* assumed to be truthful about the data: the design makes no claim that the committed value is medically correct. Denial of service is out of scope.

B. Design goals

- *G1, record confidentiality.* Observers and operators learn nothing about a record's contents beyond its size.

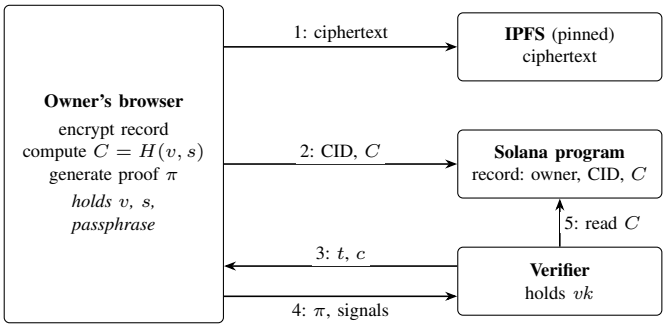


Fig. 1. Architecture and data flow. Steps 1–2 create a record; steps 3–5 are one disclosure. Step 4 carries the record address, the proof π and the public signals. The private count and salt never leave the owner's browser.

- *G2, minimal disclosure.* From an accepted proof a verifier learns that the count is at least the threshold and nothing else about the count.
- *G3, binding to a record.* An accepted proof is about the value that was committed when the record at the stated address was created.
- *G4, session freshness.* A proof made for one challenge is not accepted for another.
- *G5, local proving.* No party other than the owner's device handles the private value or the salt in clear.

C. Architecture

Figure 1 shows the components. The owner's browser performs all operations on private data: encryption, commitment and proving. The pinning service receives only ciphertext, through a server-side route that holds the service credential. The Solana program stores one small account per record. The verifier needs only the verification key, read access to the chain, and the proof.

D. Record creation

Let v be the private count. To create a record the owner's browser

1) samples a salt s of 248 random bits and stores it as a field of the record;
2) computes the commitment $C = H(v, s)$;
3) derives a 256-bit key from the owner's passphrase with PBKDF2 and a fresh 128-bit salt, encrypts the record (including s) with AES-256-GCM under a fresh 96-bit initialisation vector, and uploads the result to IPFS, obtaining a CID;
4) sends an `init_record` transaction that creates the record account and stores the owner's public key, the CID, a client-supplied timestamp and C.

The account address is a PDA derived from the seeds (`"record"`, owner key, timestamp), so each upload creates a new account and existing accounts are never overwritten. The program stores C as 32 opaque bytes; it neither interprets nor checks it. Keeping the salt inside the encrypted record means that the owner needs only the passphrase to prove again later from any device.

E. Disclosure protocol

A disclosure involves the following steps.

1) The verifier chooses a threshold t and a fresh random challenge c, and sends both to the owner.
2) The owner's browser generates a Groth16 proof π for the relation in Section IV-F with private inputs (v, s) and public inputs (t, c), and sends the verifier the record address, π and the public signals (b, C', t', c').
3) The verifier reads the commitment C from the record account at that address, directly from a Solana node.
4) The verifier accepts if and only if

$$C' = C, \qquad t' = t, \qquad c' = c, \qquad b = 1, \\ \mathsf{Verify}\big(vk,\ (b, C', t', c'),\ \pi\big) = 1. \tag{1}$$

The verifier never takes the commitment from the prover's message as given; it is compared with the on-chain value. Each failed condition yields a distinct rejection reason in the implementation, which makes misuse easier to diagnose.

F. The circuit

Let $\mathbb{F}_p$ be the scalar field of the curve and $n = 32$. The circuit enforces the relation

$$\mathcal{R} = \big\{\, ((b, C, t, c),\ (v, s)) \ :\ v, t \in [0, 2^n), \\ C = H(v, s),\ \ b = 1 \text{ if } v \geq t,\ \ b = 0 \text{ otherwise} \,\big\} \tag{2}$$

with (v, s) private and (b, C, t, c) public. The comparison is computed as $t < v+1$ with a comparator on $n+1$ bits, because $v + 1$ can reach 2^n.

Two details matter for soundness. First, the comparator from the Circom standard library is correct only when both operands fit in the stated number of bits. The baseline circuit relied on that precondition without enforcing it. The new circuit decomposes v and t into n bits each, so the bound is part of the proved statement rather than an assumption about the prover. Second, the challenge c does not take part in the predicate, and a public input that appears in no constraint may not be bound by the proof. The circuit therefore includes one multiplication constraint, $c \cdot c$, whose only purpose is to tie c into the constraint system.

The bit b is an output rather than a hard constraint. A proof with $b = 0$ is a valid proof that the count is *below* the threshold; the verifier's rule (1) requires $b = 1$.

V. Implementation

The prototype has four parts.

a) Circuit: The circuit is about fifty lines of Circom and uses the bit-decomposition, comparator and Poseidon templates of circomlib. It is compiled with full constraint simplification. The proving and verification keys come from a single-contributor setup run with snarkjs (Section VII-B).

b) On-chain program: The program is written in Rust with Anchor 0.30.1. It has one instruction, `init_record`, and one account type holding the owner key (32 bytes), the CID as a string of at most 128 bytes, a 64-bit timestamp and the 32-byte commitment. With Anchor's 8-byte type discriminator and the 4-byte string length prefix the account occupies 212 bytes. A CID longer than 128 bytes is rejected with a dedicated error. The owner must sign and pays for the account.

c) Client: The web client is a Next.js application. It uses the Web Cryptography API for PBKDF2 (HMAC-SHA-256, 120,000 iterations) and AES-256-GCM, and loads snarkjs, the WebAssembly witness generator (1.75 MB) and the proving key (206.9 kB) to prove in the browser. The commitment is computed outside the circuit with an independent Poseidon implementation, and a test checks that the two agree. The client contains an owner view, which creates records and generates proofs, and a verifier view, which reads a record account by address and applies rule (1). The verifier view needs no wallet.

d) Auxiliary services: Uploads to the pinning service pass through a server-side route that holds the service credential; it sees ciphertext only. A small optional HTTP service verifies a proof against the verification key for clients that cannot run snarkjs. Unlike the baseline's proof service, it never receives private inputs.

VI. Evaluation

The evaluation answers three questions. What does binding the proof to the record cost in circuit size and time? Is proving on the owner's device practical? What does a record cost on chain?

A. Setup and method

All measurements were taken on one laptop: an Apple M1 system with 8 cores (4 performance and 4 efficiency) and 8 GB of memory, running macOS 26.6.2. Software versions were Node.js 24.10.0, Circom 2.2.3, circomlib 2.0.5, snarkjs 0.7.6, Anchor 0.30.1 and the Solana tool suite 3.1.13.

We compare two circuits. *Baseline* is the threshold-only circuit of the original prototype, with one private input and no commitment, challenge or range checks. *Bound* is the circuit of Section IV-F. Timings in Node.js are wall-clock times over 100 runs after 5 unmeasured warm-up runs. Browser timings were taken in Chromium 156 on the same machine with a production build of the client, over 30 runs after 3 warm-up runs. Encryption timings use the client's own encryption functions over 30 runs. On-chain costs were measured on a local Solana test validator with the program loaded, over 20 transactions with a 59-character CID. We report medians with the 5th and 95th percentiles.

We did not measure confirmation latency on a public Solana cluster or upload latency to a pinning service; both depend on network conditions and on third-party services, and the numbers below should not be read as including them.

B. Circuit size

Table I compares the two circuits. Binding raises the number of constraints from 37 to 339, a factor of 9.2. Most of the increase comes from the commitment: a circuit containing only the two-input Poseidon hash compiles to 240 constraints, about 71% of the total. The range checks and the wider comparator

TABLE I
SIZE OF THE CONSTRAINT SYSTEM AND OF THE ARTIFACTS.

Quantity	Baseline	Bound
R1CS constraints	37	339
Wires	39	341
Private inputs	1	2
Public signals	2	4
Witness generator (bytes)	36,469	1,750,062
Proving key (bytes)	22,333	206,869
Verification key, JSON (bytes)	3,109	3,476
Proof, JSON (bytes)	721	721
Public signals, JSON (bytes)	9	120

TABLE II
TIME IN MILLISECONDS: MEDIAN (5TH–95TH PERCENTILE).

Operation	Baseline	Bound
Node.js, $n = 100$		
Witness generation	5.3 (4.4–6.2)	30.6 (30.1–31.3)
Groth16 proving	22.9 (20.1–26.1)	74.8 (67.9–78.9)
Witness + proving	30.2 (28.8–32.9)	108.4 (103.4–115.5)
Verification	12.3 (12.1–14.0)	13.4 (13.2–13.8)
Browser (Chromium 156), $n = 30$		
Witness + proving	—	89.4 (82.8–101.1)
Verifier check	—	14.1 (13.6–15.0)

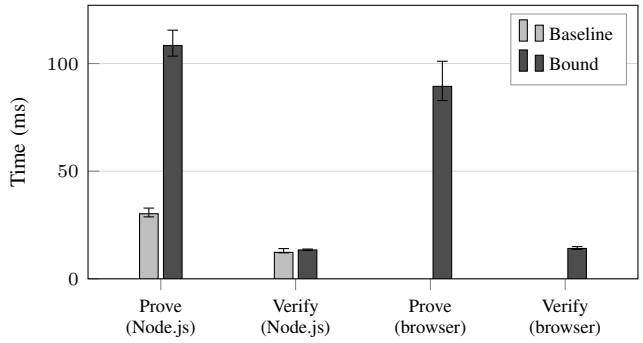


Fig. 2. Median proving and verification time. Whiskers show the 5th and 95th percentiles. The baseline was not run in the browser because it proved on a server.

TABLE III
CLIENT-SIDE ENCRYPTION AND DECRYPTION (MEDIAN, MS). "STORED" IS THE SIZE OF THE JSON OBJECT PINNED TO IPFS.

Plaintext (bytes)	Stored (bytes)	Encrypt (ms)	Decrypt (ms)
228	451	23.4	23.4
1,024	1,511	23.5	23.4
16,384	21,991	23.7	23.6
65,536	87,527	24.6	23.8
262,144	349,671	27.4	24.8

account for most of the rest. Compiler simplification matters: without it the same circuit has 622 constraints, of which 280 are linear and are eliminated by simplification.

The proof is the same size in both cases, as expected for Groth16, whose proofs always consist of three group elements [14]; its JSON encoding is 721 bytes. The public signals grow because they now include the commitment and the challenge. The artifact that grows most is the witness generator, from 36.5 kB to 1.75 MB, because it embeds the Poseidon round constants. This is a one-time download for the owner's browser and can be cached.

C. Proving and verification time

Table II and Fig. 2 give the timings. In Node.js, witness generation plus proving takes 108.4 ms for the bound circuit against 30.2 ms for the baseline, a factor of 3.6 for 9.2 times as many constraints. Verification time is practically unchanged, 13.4 ms against 12.3 ms, because Groth16 verification cost depends on the number of public inputs and not on the size of the circuit.

In the browser, the complete proving step has a median of 89.4 ms and a 95th percentile of 101.1 ms once the artifacts are loaded. The first proof after a page load took 257.1 ms in our run, which includes fetching and compiling the witness generator. The verifier's complete check, including the comparisons of rule (1), has a median of 14.1 ms. For this circuit, proving on the owner's device is therefore well within interactive latency on a laptop, and the server-side prover of the baseline is not needed for performance reasons. We did not measure phones or low-end devices, where proving will be slower.

D. Client-side encryption

Table III shows encryption and decryption times for records of increasing size. Key derivation alone takes 23.3 ms and dominates: the sample record encrypts in 23.4 ms and a record of 256 KiB in 27.4 ms. The stored object is larger than the plaintext because the ciphertext is Base64-encoded and wrapped with its salt, initialisation vector and algorithm labels; the sample record of 228 bytes becomes 451 bytes.

That key derivation takes only about 23 ms is not purely good news. The same cost applies to each guess of an attacker who downloads the public ciphertext, and the configured 120,000 iterations are below the 600,000 that OWASP currently recommends for this function [37]. We discuss this in Section VII-B.

E. On-chain cost

Table IV lists the cost of `init_record`. The record account occupies 212 bytes, 32 more than in the baseline, and requires a refundable deposit of 2,366,400 lamports (0.0023664 SOL). This matches the documented formula for the minimum balance [25]. Storing the commitment adds 222,720 lamports to the deposit compared with the baseline layout. The transaction is 347 bytes, 28% of the 1,232-byte limit [27], and pays the base fee of 5,000 lamports for its single signature.

The instruction consumed between 7,402 and 13,402 compute units, far below the default budget of 200,000 [28]. The observed values differ by exact multiples of 1,500 units. We attribute this to the search for the PDA bump seed, which depends on the owner key and timestamp and therefore varies between records; we did not instrument the runtime to confirm

TABLE IV
ON-CHAIN COST OF CREATING ONE RECORD (LOCAL TEST VALIDATOR).

Quantity	Value
Record account size (bytes)	212
Rent-exempt deposit (lamports)	2,366,400
Transaction size (bytes)	347
Compute units consumed	7,402–13,402
Transaction fee (lamports)	5,000
Total debit to owner (lamports)	2,371,400

the attribution. On the local validator a transaction reached the *confirmed* commitment level in a median of 480 ms; this figure describes the test setup only.

The on-chain cost is independent of the size of the health record, since the chain stores only the CID and the commitment. Proof verification costs nothing on chain because it happens off chain.

F. Functional validation

The implementation has 28 automated tests. Eleven exercise the circuit: correct outputs above, at and below the threshold; the largest 32-bit values; agreement of the in-circuit commitment with an independent Poseidon implementation; rejection of out-of-range inputs at witness generation; and rejection of proofs whose public commitment, challenge or validity bit has been altered. Six run the program on a local validator: correct storage of all fields, the exact account size, acceptance of a 128-byte CID and rejection of a 129-byte one, rejection of a duplicate record, and rejection of a record whose stated owner did not sign. Eleven cover the client logic, including each rejection reason of rule (1). In addition, the verifier view was exercised interactively in a browser against a record on the local validator: a matching proof was accepted, and the same proof was rejected after changing the expected challenge and after raising the expected threshold. The upload path was tested through the program's client library; the wallet extension's signing dialogue in the browser is not covered by automated tests.

VII. Security Analysis and Limitations

A. How the goals are met

The arguments in this subsection are informal and rest on the assumptions of Section IV-A.

G1, record confidentiality. Only the AES-GCM ciphertext, its salt and its initialisation vector are stored on IPFS, and only the CID and the commitment are stored on chain. Each record is encrypted under a key derived with a fresh salt, so an initialisation vector is never reused under the same key. Confidentiality reduces to the security of AES-GCM and to the strength of the passphrase.

G2, minimal disclosure. Groth16 is zero-knowledge [14], so the proof reveals nothing beyond the public signals (b, C, t, c). The threshold and challenge were chosen by the verifier. The commitment $C = H(v, s)$ is already public on chain; the count has very few plausible values, so without a salt it could be recovered by trying each one, and the 248-bit random salt prevents this. We treat $H(v, \cdot)$ with a uniformly random second input as hiding v, which is a heuristic assumption about Poseidon and not a proved property.

G3, binding to a record. If the verifier accepts, then by the knowledge soundness of Groth16 the prover knows (v, s) with $H(v, s) = C$ and $v \geq t$, where C is the value read from the chain. The record account cannot be modified after creation, since the program has no instruction that writes to an existing account. Finding a second opening (v', s') of the same commitment with $v' \neq v$ would be a collision in Poseidon. The proof is therefore about the value committed at creation time. The range checks close the under-constrained comparison discussed in Section IV-F.

G4, session freshness. The challenge is a public input, so a proof verifies only together with the challenge it was made for. A verifier that draws a fresh challenge for each session will reject a proof recorded in an earlier session. Tests confirm that altering the challenge, the commitment or the validity bit of a genuine proof makes verification fail.

G5, local proving. Witness generation and proving run in the owner's browser. The verification service and the pinning route receive no private input.

B. Limitations

We list the limitations of the design and of the prototype in what we judge to be decreasing order of importance.

The data is self-asserted. Nothing prevents an owner from committing to a count that is false. The system proves consistency with a value fixed in the past, not correctness of that value. A deployment would need an issuer, such as a clinic, to sign the commitment or the underlying attributes, with the signature checked by the verifier or inside the circuit, as in credential systems [43], [44].

The proof is not bound to the presenter. Anyone who knows (v, s) can prove. The challenge stops later replay but not a relay in which an intermediary forwards a verifier's challenge to the real owner and passes the answer back as its own. Since the record account names the owner's public key, the verifier could additionally require a signature on the challenge under that key; the prototype does not do this.

Repeated queries leak the value. Each accepted or rejected proof tells the verifier one bit. A verifier, or several colluding verifiers, who obtain answers for different thresholds can narrow down the count, in the worst case exactly. The owner decides which requests to answer, but the prototype offers no policy support for this.

Single-party setup. The proving key was generated by one contributor on a development machine. Anyone who retained the setup randomness could forge proofs. A real deployment needs a multi-party ceremony [18] or a proof system without a trusted setup [20].

Passphrase-based encryption of public ciphertext. The ciphertext is public and cannot be recalled, so an attacker can test passphrases offline without limit. The configured iteration count is below current guidance [37], and a leaked passphrase compromises the record permanently. A memory-hard key derivation function or a key held by the wallet would be stronger.

Linkability and metadata. Records are linked to the owner's wallet address, and their creation times and number are public. All proofs about one record carry the same commitment and are therefore linkable to each other and to that record.

No revocation or erasure. The program cannot update or close a record, and content on IPFS persists while any node keeps it. This conflicts with a right to erasure such as that of Article 17 of the GDPR [3] if the ciphertext or the commitment is considered personal data, a question we do not resolve here.

Off-chain verification. Proofs are verified by the verifier's own software. The verifier must obtain the correct verification key through a channel it trusts; the prototype serves it with the application. The timestamp in a record is supplied by the client and is not checked against the cluster clock.

Scope of the evaluation. One claim type, one machine, a local validator, no public-cluster or pinning-service latency, no mobile devices and no user study.

C. Future work

The most valuable extension is issuer attestation, which would turn the self-asserted commitment into a credential. Binding proofs to the owner's wallet key, a multi-party setup, and anchoring a hash of the verification key on chain address the next three limitations. The circuit generalises directly to other numeric predicates and to several attributes committed together; measuring how proving time grows with the number of attributes on phones is the natural next experiment. Verifying the proof inside the Solana program would let other programs act on a disclosure, at a compute cost that remains to be measured.

VIII. Conclusion

A zero-knowledge proof about a health record is only as meaningful as its connection to a stored record and to a verification session. Starting from a prototype that lacked both connections and revealed the private value to a server, we added a salted Poseidon commitment stored on Solana, a verifier-chosen challenge, enforced range checks and client-side proving. On a laptop the resulting circuit has 339 constraints, proves in about 89.4 ms in a browser and verifies in about 13.4 ms, and each record costs a 212-byte account with a refundable deposit of 0.0023664 SOL. The design gives a verifier a yes-or-no answer about a committed value without access to the record. It does not establish that the committed value is true, and we have set out that and the other limitations that stand between this prototype and a deployable system.

Acknowledgment

Claude (Anthropic), a large language model used through the Claude Code tool, assisted in this work. It was used to draft the text of all sections of the manuscript; to implement the commitment and challenge extension of the circuit, the client-side proving and verification code, the test suites and the benchmark scripts; and to generate the tables and the timing figure from the recorded measurement files. Every numerical result reported here was obtained by executing the code on the hardware described in Section VI; none was produced by the model. Each reference was checked against its publisher, standards-body or DOI registry record. The authors reviewed the manuscript and the code and take full responsibility for the content.

References

[1] P. C. Tang, J. S. Ash, D. W. Bates, J. M. Overhage, and D. Z. Sands, "Personal health records: Definitions, benefits, and strategies for overcoming barriers to adoption," *Journal of the American Medical Informatics Association*, vol. 13, no. 2, pp. 121–126, 2006.

[2] A. Roehrs, C. A. da Costa, R. da Rosa Righi, and K. S. F. de Oliveira, "Personal health records: A systematic literature review," *Journal of Medical Internet Research*, vol. 19, no. 1, p. e13, 2017.

[3] European Parliament and Council of the European Union, "Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation)," Official Journal of the European Union, 2016. [Online]. Available: https://eur-lex.europa.eu/eli/reg/2016/679/oj

[4] T.-T. Kuo, H.-E. Kim, and L. Ohno-Machado, "Blockchain distributed ledger technologies for biomedical and health care applications," *Journal of the American Medical Informatics Association*, vol. 24, no. 6, pp. 1211–1220, 2017.

[5] T. McGhin, K.-K. R. Choo, C. Z. Liu, and D. He, "Blockchain in healthcare applications: Research challenges and opportunities," *Journal of Network and Computer Applications*, vol. 135, pp. 62–75, 2019.

[6] A. Azaria, A. Ekblaw, T. Vieira, and A. Lippman, "MedRec: Using blockchain for medical data access and permission management," in *2016 2nd International Conference on Open and Big Data (OBD)*, 2016, pp. 25–30.

[7] G. Zyskind, O. Nathan, and A. Pentland, "Decentralizing privacy: Using blockchain to protect personal data," in *2015 IEEE Security and Privacy Workshops*, 2015, pp. 180–184.

[8] G. G. Dagher, J. Mohler, M. Milojkovic, and P. B. Marella, "Ancile: Privacy-preserving framework for access control and interoperability of electronic health records using blockchain technology," *Sustainable Cities and Society*, vol. 39, pp. 283–297, 2018.

[9] Q. Xia, E. B. Sifah, K. O. Asamoah, J. Gao, X. Du, and M. Guizani, "MeDShare: Trust-less medical data sharing among cloud service providers via blockchain," *IEEE Access*, vol. 5, pp. 14 757–14 767, 2017.

[10] A. Shahnaz, U. Qamar, and A. Khalid, "Using blockchain for electronic health records," *IEEE Access*, vol. 7, pp. 147 782–147 795, 2019.

[11] J. Sun, X. Yao, S. Wang, and Y. Wu, "Blockchain-based secure storage and access scheme for electronic medical records in IPFS," *IEEE Access*, vol. 8, pp. 59 389–59 401, 2020.

[12] S. Goldwasser, S. Micali, and C. Rackoff, "The knowledge complexity of interactive proof systems," *SIAM Journal on Computing*, vol. 18, no. 1, pp. 186–208, 1989.

[13] B. Parno, J. Howell, C. Gentry, and M. Raykova, "Pinocchio: Nearly practical verifiable computation," in *2013 IEEE Symposium on Security and Privacy*, 2013, pp. 238–252.

[14] J. Groth, "On the size of pairing-based non-interactive arguments," in *Advances in Cryptology – EUROCRYPT 2016*, ser. Lecture Notes in Computer Science. Berlin, Heidelberg: Springer, 2016, pp. 305–326.

[15] E. Ben-Sasson, A. Chiesa, C. Garman, M. Green, I. Miers, E. Tromer, and M. Virza, "Zerocash: Decentralized anonymous payments from Bitcoin," in *2014 IEEE Symposium on Security and Privacy*, 2014, pp. 459–474.

[16] A. Kosba, A. Miller, E. Shi, Z. Wen, and C. Papamanthou, "Hawk: The blockchain model of cryptography and privacy-preserving smart contracts," in *2016 IEEE Symposium on Security and Privacy (SP)*, 2016, pp. 839–858.

[17] X. Sun, F. R. Yu, P. Zhang, Z. Sun, W. Xie, and X. Peng, "A survey on zero-knowledge proof in blockchain," *IEEE Network*, vol. 35, no. 4, pp. 198–205, 2021.

[18] E. Ben-Sasson, A. Chiesa, M. Green, E. Tromer, and M. Virza, "Secure sampling of public parameters for succinct zero knowledge proofs," in *2015 IEEE Symposium on Security and Privacy*, 2015, pp. 287–304.

[19] P. S. L. M. Barreto and M. Naehrig, "Pairing-friendly elliptic curves of prime order," in *Selected Areas in Cryptography*, ser. Lecture Notes in Computer Science. Berlin, Heidelberg: Springer, 2006, pp. 319–331.

[20] B. Bünz, J. Bootle, D. Boneh, A. Poelstra, P. Wuille, and G. Maxwell, "Bulletproofs: Short proofs for confidential transactions and more," in *2018 IEEE Symposium on Security and Privacy (SP)*, 2018, pp. 315–334.

[21] M. Bellés-Muñoz, M. Isabel, J. L. Muñoz-Tapia, A. Rubio, and J. Baylina, "Circom: A circuit description language for building zero-knowledge applications," *IEEE Transactions on Dependable and Secure Computing*, vol. 20, no. 6, pp. 4733–4751, 2023.

[22] iden3, "snarkjs: zkSNARK implementation in JavaScript and WASM," Software repository, accessed 13 November 2026. [Online]. Available: https://github.com/iden3/snarkjs

[23] S. Pailoor, Y. Chen, F. Wang, C. Rodríguez, J. V. Geffen, J. Morton, M. Chu, B. Gu, Y. Feng, and I. Dillig, "Automated detection of under-constrained circuits in zero-knowledge proofs," *Proceedings of the ACM on Programming Languages*, vol. 7, no. PLDI, pp. 1510–1532, 2023.

[24] L. Grassi, D. Khovratovich, C. Rechberger, A. Roy, and M. Schofnegger, "Poseidon: A new hash function for zero-knowledge proof systems," in *30th USENIX Security Symposium (USENIX Security 21)*, 2021, pp. 519–535. [Online]. Available: https://www.usenix.org/conference/usenixsecurity21/presentation/grassi

[25] Solana Foundation, "Accounts," Solana Documentation, accessed 13 November 2026. [Online]. Available: https://solana.com/docs/core/accounts

[26] ——, "Program derived addresses (PDAs)," Solana Documentation, accessed 13 November 2026. [Online]. Available: https://solana.com/docs/core/pda

[27] ——, "Transactions," Solana Documentation, accessed 13 November 2026. [Online]. Available: https://solana.com/docs/core/transactions

[28] ——, "Fees," Solana Documentation, accessed 13 November 2026. [Online]. Available: https://solana.com/docs/core/fees

[29] "Anchor framework documentation," anchor-lang.com, accessed 13 November 2026. [Online]. Available: https://www.anchor-lang.com/docs

[30] J. Benet, "IPFS – content addressed, versioned, P2P file system," arXiv preprint arXiv:1407.3561, 2014. [Online]. Available: https://arxiv.org/abs/1407.3561

[31] D. Trautwein, A. Raman, G. Tyson, I. Castro, W. Scott, M. Schubotz, B. Gipp, and Y. Psaras, "Design and evaluation of IPFS: A storage layer for the decentralized web," in *Proceedings of the ACM SIGCOMM 2022 Conference*, 2022, pp. 739–752.

[32] E. Daniel and F. Tschorsch, "IPFS and friends: A qualitative comparison of next generation peer-to-peer data networks," *IEEE Communications Surveys & Tutorials*, vol. 24, no. 1, pp. 31–52, 2022.

[33] M. Dworkin, "Recommendation for block cipher modes of operation: Galois/Counter Mode (GCM) and GMAC," National Institute of Standards and Technology, NIST Special Publication 800-38D, 2007.

[34] K. Moriarty, B. Kaliski, and A. Rusch, "PKCS #5: Password-based cryptography specification version 2.1," RFC Editor, RFC 8018, 2017.

[35] M. S. Turan, E. Barker, W. Burr, and L. Chen, "Recommendation for password-based key derivation: Part 1: Storage applications," National Institute of Standards and Technology, NIST Special Publication 800-132, 2010.

[36] M. Watson, "Web cryptography API," W3C Recommendation, 2017. [Online]. Available: https://www.w3.org/TR/2017/REC-WebCryptoAPI-20170126/

[37] OWASP Foundation, "Password storage cheat sheet," OWASP Cheat Sheet Series, accessed 13 November 2026. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html

[38] X. Yue, H. Wang, D. Jin, M. Li, and W. Jiang, "Healthcare data gateways: Found healthcare intelligence on blockchain with novel privacy risk control," *Journal of Medical Systems*, vol. 40, no. 10, p. 218, 2016.

[39] P. Zhang, J. White, D. C. Schmidt, G. Lenz, and S. T. Rosenbloom, "FHIRChain: Applying blockchain to securely and scalably share clinical data," *Computational and Structural Biotechnology Journal*, vol. 16, pp. 267–278, 2018.

[40] S. Tanwar, K. Parekh, and R. Evans, "Blockchain-based electronic healthcare record system for healthcare 4.0 applications," *Journal of Information Security and Applications*, vol. 50, p. 102407, 2020.

[41] R. Zhang, R. Xue, and L. Liu, "Security and privacy on blockchain," *ACM Computing Surveys*, vol. 52, no. 3, pp. 1–34, 2020.

[42] B. Sharma, R. Halder, and J. Singh, "Blockchain-based interoperable healthcare using zero-knowledge proofs and proxy re-encryption," in *2020 International Conference on COMmunication Systems & NETworkS (COMSNETS)*, 2020, pp. 1–6.

[43] J. Camenisch and A. Lysyanskaya, "An efficient system for non-transferable anonymous credentials with optional anonymity revocation," in *Advances in Cryptology – EUROCRYPT 2001*, ser. Lecture Notes in Computer Science. Berlin, Heidelberg: Springer, 2001, pp. 93–118.

[44] M. Sporny, T. Thibodeau Jr, I. Herman, G. Cohen, and M. B. Jones, "Verifiable credentials data model v2.0," W3C Recommendation, 2025. [Online]. Available: https://www.w3.org/TR/vc-data-model-2.0/